



BÁO CÁO TỔNG KẾT ĐỒ ÁN

Xây dựng Hệ thống Giám sát An ninh và Phân tích Hành vi Tấn công Tự động dựa trên Log F5-ASM tích hợp LLM

Người thực hiện: Nguyễn Khánh

I. GIỚI THIỆU ĐỀ TÀI

Trong kỷ nguyên số, các hệ thống Web Application Firewall (WAF) như **F5-ASM** tạo ra hàng triệu dòng nhật ký (logs) mỗi ngày. Thách thức lớn nhất của các chuyên gia SOC (Security Operations Center) không phải là thiếu dữ liệu, mà là "**nhiều dữ liệu**". Việc phân tích thủ công để tìm ra một cuộc tấn công thực sự giữa hàng ngàn cảnh báo giả là điều bất khả thi.

Dự án này được xây dựng nhằm giải quyết bài toán trên bằng cách kết hợp sức mạnh của:

- Dòng Log tiêu chuẩn:** Từ thiết bị bảo mật hàng đầu thế giới F5-ASM.
- Hệ sinh thái Quan sát (Observability):** Grafana, Loki, Promtail.
- Mô hình ngôn ngữ lớn (LLMs):** Để phân tích hành vi theo ngữ cảnh và hỗ trợ ra quyết định phản ứng tức thì.

II. CHI TIẾT DỮ LIỆU ĐẦU VÀO VÀ ĐẦU RA (INPUT/OUTPUT)

2.1. Dữ liệu đầu vào (Input)

Dữ liệu gốc là **F5-ASM Event Logs** được cấu hình theo định dạng JSON định danh (Key-Value), bao gồm các trường thông tin quan trọng:

- source_ip, dest_ip:** Định danh nguồn và đích.
- request_url, request_method:** Nội dung truy cập.
- event_class, name:** Loại hình vi phạm được WAF nhận diện sơ bộ.
- action:** Trạng thái xử lý của WAF (passed hoặc blocked).



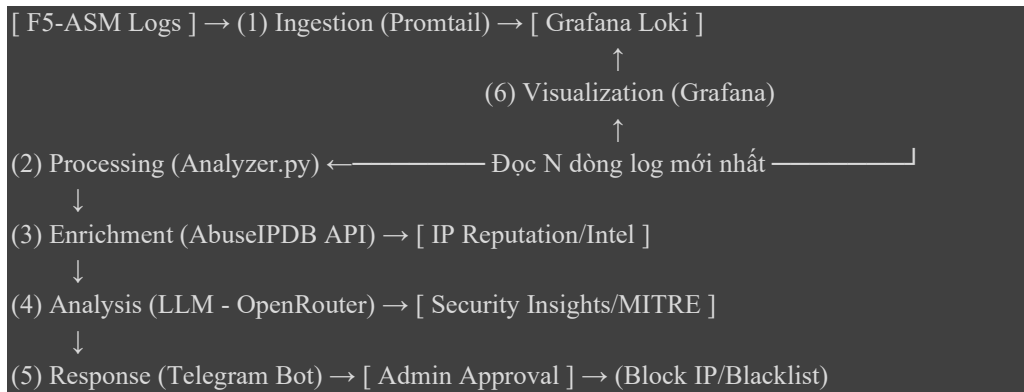
2.2. Dữ liệu đầu ra (Output)

Hệ thống tạo ra các tầng thông tin có giá trị cao:

- **Security Insights (JSON):** Kết quả phân tích từ AI bao gồm mức độ nghiêm trọng (Severity), phân loại kỹ thuật tấn công theo chuẩn **MITRE ATT&CK**.
- **Visualization Dashboard:** Bản đồ nhiệt (Geomap) vị trí hacker, biểu đồ tròn phân loại tấn công, và bảng thống kê Blacklist.
- **Incident Response:** Các hành động phản ứng (Block IP) được ghi nhận vào hệ thống lưu trữ.

III. KIẾN TRÚC HỆ THỐNG (PIPELINE)

Hệ thống được thiết kế theo mô hình **Pipeline tuần tự**, đảm bảo dữ liệu được xử lý luân phiên và không bị nghẽn:



1. **Giai đoạn Thu thập (Ingestion):** Promtail theo dõi file log và đẩy về Loki.
2. **Giai đoạn Xử lý (Processing):** Script Python (Analyzer) đọc n dòng log mới nhất, gom nhóm theo địa chỉ IP (Grouping).
3. **Giai đoạn Làm giàu dữ liệu (Enrichment):** Tích hợp API AbuseIPDB để lấy thông tin Threat Intelligence (điểm tin cậy của IP).
4. **Giai đoạn Phân tích (Analysis):** AI (LLM qua OpenRouter) nhận ngữ cảnh chuỗi hành vi để đưa ra kết luận bảo mật.
5. **Giai đoạn Phản ứng (Response):** Hệ thống gửi cảnh báo tương tác qua Telegram Bot để quản trị viên phê duyệt chặn IP.
6. **Giai đoạn Hiển thị (Visualization):** Grafana truy vấn Loki để vẽ Dashboard tổng thể.

IV. THIẾT LẬP MÔI TRƯỜNG GIẢ LẬP (ENVIRONMENT SETUP)

Để dự án có thể vận hành trong điều kiện thực tập, môi trường giả lập được thiết lập để tiệm cận thực tế:

4.1. Hạ tầng phần mềm

- **Hệ điều hành:** Ubuntu Server (Linux).
- **Stack giám sát:** Grafana v10.x, Loki v2.x, Promtail.



- **Ngôn ngữ lập trình:** Python 3.10+ (Thư viện: openai, requests, python-telegram-bot).

4.2. Cấu hình Giả lập Log (Log Simulation)

Do không thể truy cập trực tiếp vào thiết bị F5-ASM thật trong mọi thời điểm, giải pháp thay thế là xây dựng script `collector.py`:

- **Nhiệm vụ:** Mô phỏng luồng log đổ về liên tục.
- **Kịch bản:** Giả lập các cuộc tấn công phổ biến như SQL Injection, Path Traversal, và Brute Force bằng cách chèn các dòng log JSON chuẩn format F5 vào file `collector.log`.

4.3. Kết nối API

- **OpenRouter API:** Kết nối với các Model LLMs mạnh mẽ (như Nemotron, GPT-4) để phân tích log.
- **AbuseIPDB API:** Truy vấn cơ sở dữ liệu danh tiếng IP toàn cầu.
- **Telegram Bot API:** Xây dựng kênh giao tiếp tương tác với quản trị viên.

V. CẤU TRÚC DỰ ÁN (PROJECT STRUCTURE)

Dự án được tổ chức theo mô hình mô-đun hóa, tách biệt giữa logic xử lý, cấu hình hệ thống giám sát và dữ liệu thực thi.

```
SIEM-project/
├── langchain_pipeline/  # Trái tim của hệ thống xử lý AI
│   ├── config.yaml    # Tham số hệ thống: Loki/Grafana URL, Model name, API Keys
│   ├── requirements.txt # Thư viện: requests, langchain, openai, python-telegram-bot...
│   └── src/
│       ├── analyzer.py  # AI Analyzer: Đọc log, gom nhóm IP, gọi Threat Intel & LLM
│       ├── collector.py  # Giả lập Log: Replay log F5 ASM từ CSV, quản lý offset và xoay vòng log
│       ├── telegram_handler.py # Bot tương tác: Gửi cảnh báo kèm nút bấm BLOCK/IGNORE
│       └── test_llm.py   # Công cụ kiểm thử nhanh logic phân tích và kết nối LLM
├── loki/
│   └── config.yaml      # Cấu hình lưu trữ, port và retention chính sách cho Loki
├── promtail/
│   └── config.yaml      # Định nghĩa các Job scrape log, parse JSON stage cho Blacklist
└── scripts/
    └── run_analyzer.sh  # Script tự động hóa: Export biến môi trường và kích hoạt venv
```

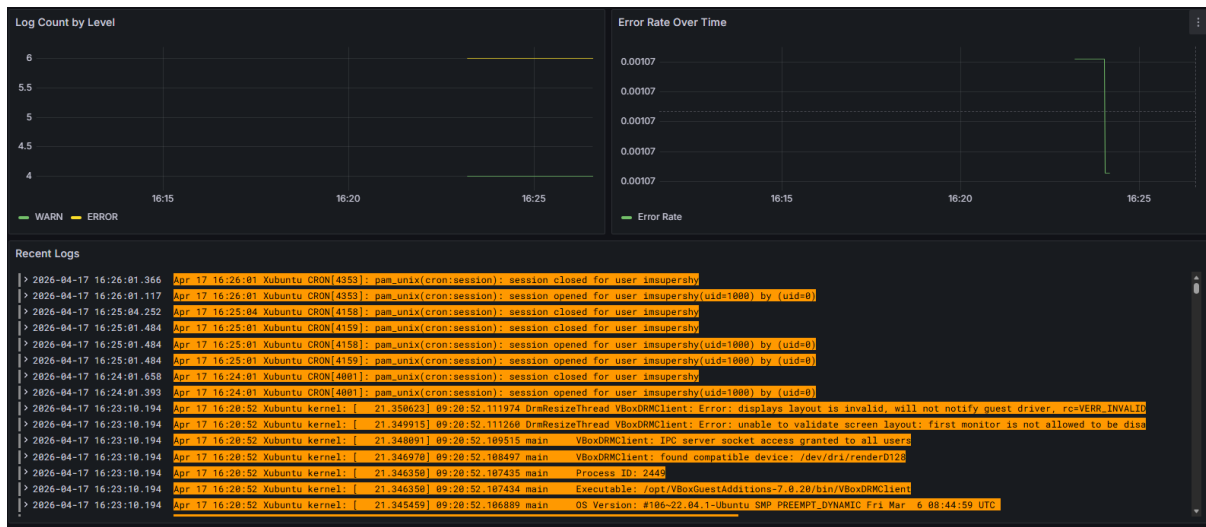
VI. KẾT QUẢ TRIỂN KHAI

Dưới đây là các cột mốc quan trọng và kết quả đầu ra của hệ thống:



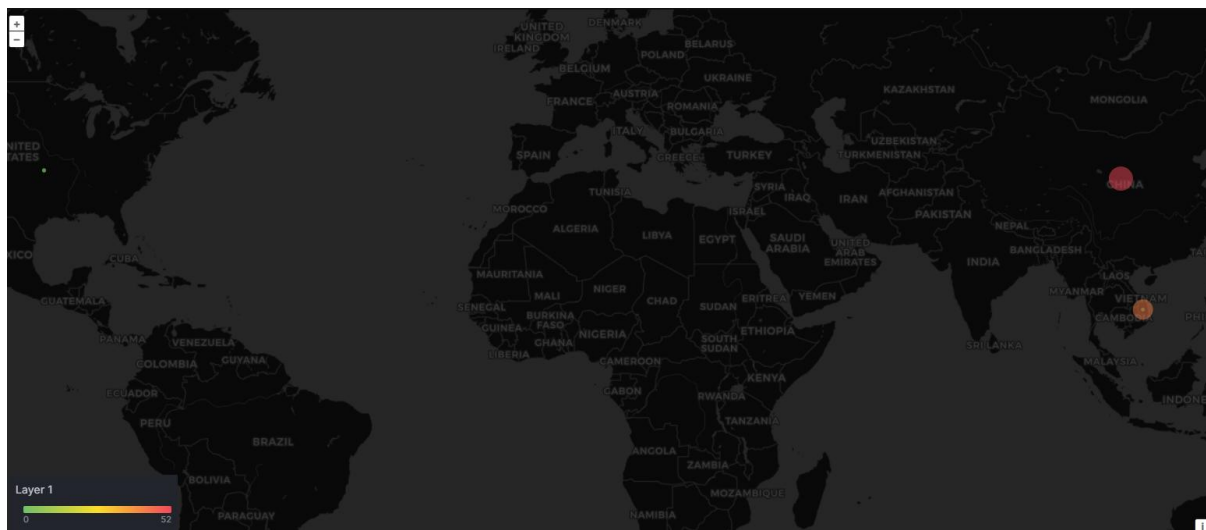
6.1. Xây dựng nền tảng và Luồng dữ liệu thô (Raw Data Pipeline)

- **Kết quả:** Thiết lập thành công hệ sinh thái **Loki - Promtail - Grafana**. Xây dựng cơ chế "Replay log" từ file CSV mẫu của F5-ASM sang file log thực tế (collector.log) để duy trì dữ liệu liên tục cho hệ thống.
- **Hình ảnh minh họa:**
 - *Chú thích:* Dữ liệu thô từ F5-ASM được Promtail thu thập và gắn nhãn (Labeling) chính xác trước khi đưa vào lưu trữ tại Loki.



6.2. Làm giàu dữ liệu với Threat Intelligence (Enrichment)

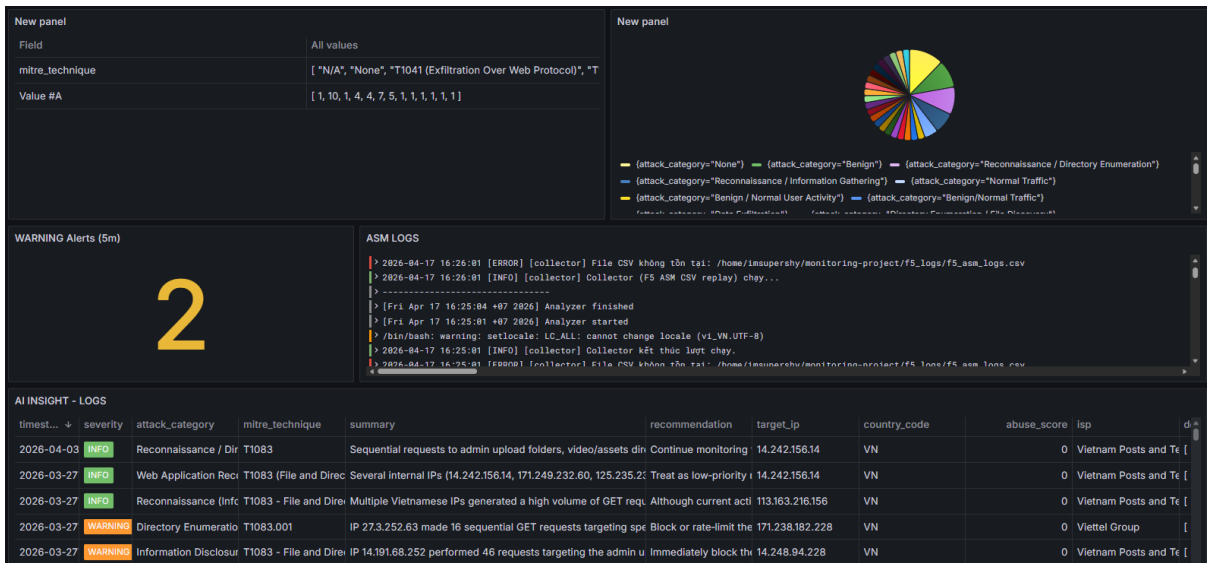
- **Kết quả:** Tích hợp API AbuseIPDB để tự động tra cứu "điểm độc hại" của IP. Xây dựng bản đồ nhiệt (Geomap) giúp xác định chính xác vị trí địa lý của nguồn tấn công.
- **Hình ảnh minh họa:**
 - *Chú thích:* Bản đồ nhiệt hiển thị mật độ tấn công từ các quốc gia, giúp định danh các vùng địa lý có nguy cơ cao.



6.3. Phân tích hành vi theo chuỗi & MITRE ATT&CK

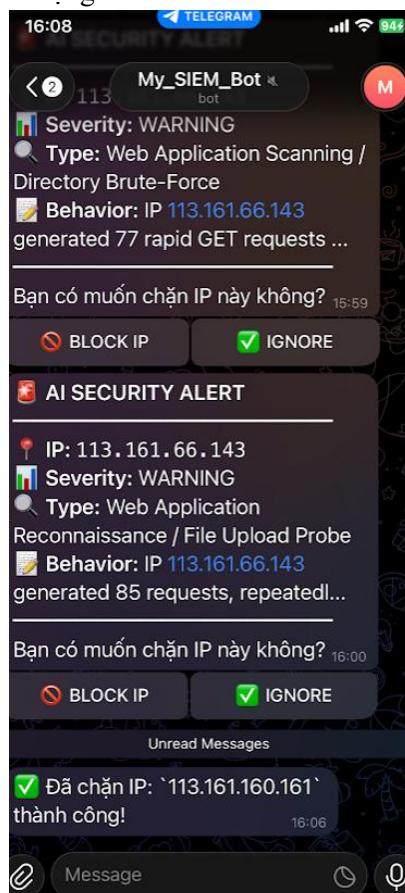


- **Kết quả:** Nâng cấp AI Analyzer với khả năng gom nhóm log theo IP (Grouping). AI không chỉ phân tích dòng log lẻ mà đã biết đọc "chuỗi hành động" để định danh kỹ thuật tấn công theo chuẩn quốc tế.
- **Hình ảnh minh họa:**
 - *Chú thích:* Bảng thống kê các kỹ thuật tấn công (ví dụ: T1190, T1110) được AI trích xuất và ánh xạ tự động từ hành vi của hacker.



6.4. Hệ thống Phản ứng Tương tác (Incident Response)

- **Kết quả:** Hoàn thiện vòng lặp SOC (Closed-loop). Khi AI phát hiện mức độ CRITICAL, quản trị viên có thể nhấn nút **BLOCK IP** trực tiếp từ Telegram. IP bị chặn sẽ tự động được cập nhật vào Blacklist và hiển thị trạng thái trên Dashboard.
- **Hình ảnh minh họa:**
 - *Chú thích:* Giao diện cảnh báo tương tác cho phép quản trị viên ra quyết định chặn IP tức thì từ thiết bị di động.





VII. ĐÁNH GIÁ VÀ TỔNG KẾT

Qua nhiều giai đoạn triển khai, hệ thống đã hoàn thiện đầy đủ các chức năng của một trung tâm SOC hiện đại:

Giai đoạn	Công nghệ áp dụng
Thu thập (Collection)	F5-ASM, Promtail, Loki
Phân tích (Analysis)	AI (LLM), Threat Intelligence
Thông báo (Alerting)	Gmail, Telegram, Grafana Alerting
Phản ứng (Response)	Telegram Interactive, Blacklisting

Kết luận: Dự án đã giải quyết tốt bài toán lọc nhiễu log bảo mật bằng trí tuệ nhân tạo và rút ngắn khoảng cách giữa “Phát hiện” và “Ngăn chặn”. Đây là nền tảng vững chắc để phát triển thành một hệ thống **SOAR** (Security Orchestration, Automation, and Response) chuyên nghiệp trong tương lai.

Dự án được đăng tải và chia sẻ trên nền tảng Github: <https://github.com/imsupershy111/SIEM-project>

VIII. NGUỒN THAM KHẢO (REFERENCES)

8.1. Hệ sinh thái Grafana (Loki & Promtail)

- **Grafana Loki Documentation:** <https://grafana.com/docs/loki/latest/> – Tài liệu hướng dẫn cấu hình lưu trữ log theo dạng label-based.
- **Promtail Pipelines & Scrape Configs:** <https://grafana.com/docs/loki/latest/send-data/promtail/pipelines/> – Hướng dẫn chi tiết về cấu hình pipeline xử lý log JSON và Regex.
- **LogQL Reference:** <https://grafana.com/docs/loki/latest/query/> – Ngôn ngữ truy vấn dữ liệu từ Loki để trực quan hóa trên Dashboard.

8.2. Trí tuệ nhân tạo và An ninh mạng

- **MITRE ATT&CK Framework:** <https://attack.mitre.org/> – Cơ sở dữ liệu về các kỹ thuật và chiến thuật tấn công của hacker.
- **OpenRouter API Documentation:** <https://openrouter.ai/docs> – Hướng dẫn tích hợp các mô hình ngôn ngữ lớn (LLM) vào ứng dụng.
- **AbuseIPDB API v2:** <https://docs.abuseipdb.com/> – Tài liệu hướng dẫn truy vấn Threat Intelligence cho địa chỉ IP.

8.3. ELK Stack (Giải pháp thay thế)

Để có cái nhìn khách quan về kiến trúc SIEM, dự án đã nghiên cứu và so sánh với mô hình ELK Stack truyền thống:

- **Elasticsearch, Logstash, Kibana (ELK) Guide:** <https://www.elastic.co/what-is/elk-stack>
- **Elastic Security (SIEM):** <https://www.elastic.co/security/siem> – Tài liệu về cách ELK xử lý và phát hiện các mối đe dọa an ninh.

8.4. Python Ecosystem



- **Python Telegram Bot SDK:** <https://python-telegram-bot.org/> – Thư viện xây dựng Bot tương tác cho hệ thống Incident Response.
- **OpenAI Python Library:** <https://github.com/openai/openai-python> – SDK chính thức để giao tiếp với các mô hình LLM.